

Brute Force – System Time Lookup Detected

Analyst Note :	Empty
Official Writeup :	Open the Security Report
Ticket :	SOC291 - System Time Lookup Detected
MITRE ATT&CK :	T1078 T1133 T1059.003 T1110 T1016 T1033 T1049 T1057 T1069 T1087 T1124
Host :	Campbell
LI Note :	I could not determine whether an authorized user or an attacker executed the command that caused the alert on the system. However, minutes before the alert, I detected Brute Force from IP 37.19.221.238.
Source Address :	172.16.17.213
Alert Trigger Reason :	Possible System Time Discovery Attempt Detected
Alert Trigger Command :	net time \EC2AMAZ-ILGVOIN

Detectar um bruteforce é simples, é só verificar uma tentativa de acesso com ID 4625 (failed logon) na mesma conta várias vezes em um curto período de tempo

Nesse caso o alerta disparou devido a um comando suspeito, net time, para verificar e o horário com o host, é necessário verificar se foi o próprio usuário que fez isso ou se é obra de um atacante que pode estar querendo se sincronizar com a rede

2024-06-10 00:52:20 OS 37.19.221.238:28453 → 172.16.17.213:3389 EventID: 4625(An account failed to log on), Username: letsdefend, Source IP: 37.19.221.238, Error Code: 0xC000006A(user name is correct but the password is wrong)
2024-06-10 00:52:18 OS 37.19.221.238:45321 → 172.16.17.213:3389 EventID: 4625(An account failed to log on), Username: letsdefend, Source IP: 37.19.221.238, Error Code: 0xC000006A(user name is correct but the password is wrong)
2024-06-10 00:52:15 OS 37.19.221.238:29745 → 172.16.17.213:3389 EventID: 4625(An account failed to log on), Username: letsdefend, Source IP: 37.19.221.238, Error Code: 0xC000006A(user name is correct but the password is wrong)
2024-06-10 00:52:01 OS 37.19.221.238:29753 → 172.16.17.213:3389 EventID: 4625(An account failed to log on), Username: root, Source IP: 37.19.221.238, Error Code: 0xC0000064(user name does not exist)
2024-06-10 00:51:57 OS 37.19.221.238:56231 → 172.16.17.213:3389 EventID: 4625(An account failed to log on), Username: guest, Source IP: 37.19.221.238, Error Code: 0xC000006A(user name is correct but the password is wrong)
2024-06-10 00:51:55 OS 37.19.221.238:41563 → 172.16.17.213:3389 EventID: 4625(An account failed to log on), Username: test, Source IP: 37.19.221.238, Error Code: 0xC0000064(user name does not exist)

Realmente, de acordo com os logs parece uma tentativa de bruteforce, o primeiro passo é ver se ele teve sucesso nisso, pois isso escalaria muito o nível do incidente

2024-06-10 00:54:18 Firewall 37.19.221.238:36213 → 172.16.17.213:3389
2024-06-10 00:54:03 OS 37.19.221.238:36213 → 172.16.17.213:3389 EventID: 4624(An account was successfully logged on.), Username: LetsDefend, Source IP: 37.19.221.238, Logon Type: 10(RemoteInteractive)
2024-06-10 00:52:58 Firewall 37.19.221.238:29753 → 172.16.17.213:3389

Verificando mais um pouco nos logs, foi achado um sucesso no login pelo mesmo IP que estava tentando logar em outras contas e com várias tentativas de falhas, ele conseguiu logar na conta letsdefend através da porta 3389 (RDP) na máquina de IP 172.16.17.213

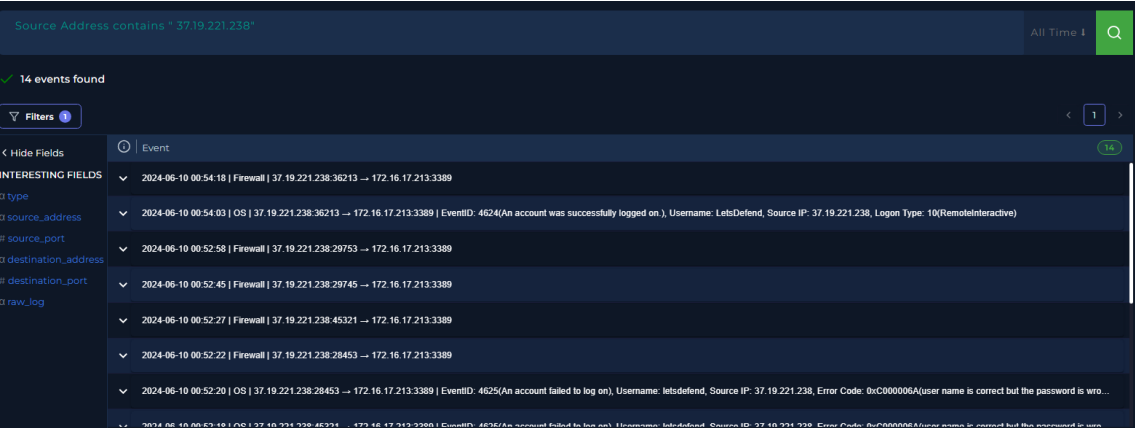
Nesse caso como o Bruteforce foi um sucesso é necessário ir no EDR verificar potenciais comandos maliciosos nesse horário

172.16.17.213	Processes	Network Action	Terminal History 10	Browser History	Results: 10
Campbell 172.16.17.213					
EVENT TIME	COMMAND LINE				
Jun 10 2024 06:58:26	tasklist /svc				
Jun 10 2024 06:58:11	netstat				
Jun 10 2024 06:57:16	ipconfig /all				
Jun 10 2024 06:57:03	ipconfig				
Jun 10 2024 06:56:42	arp -a				
Jun 10 2024 06:56:18	net time \EC2AMAZ-ILGVOIN				
Jun 10 2024 06:56:05	hostname				
Jun 10 2024 06:55:36	net user				
Jun 10 2024 06:55:14	whoami /groups				
Jun 10 2024 06:55:01	whoami				

Vendo o histórico do terminal dele, é possível observar vários comandos padrão de reconhecimento como whoami, whoami /groups, hostname, entre outros, esses comandos executados em sequência indicam um forte indício de tentativa de reconhecimento e comportamento incomum de usuário, ainda mais depois de uma tentativa bem-sucedida de bruteforce.

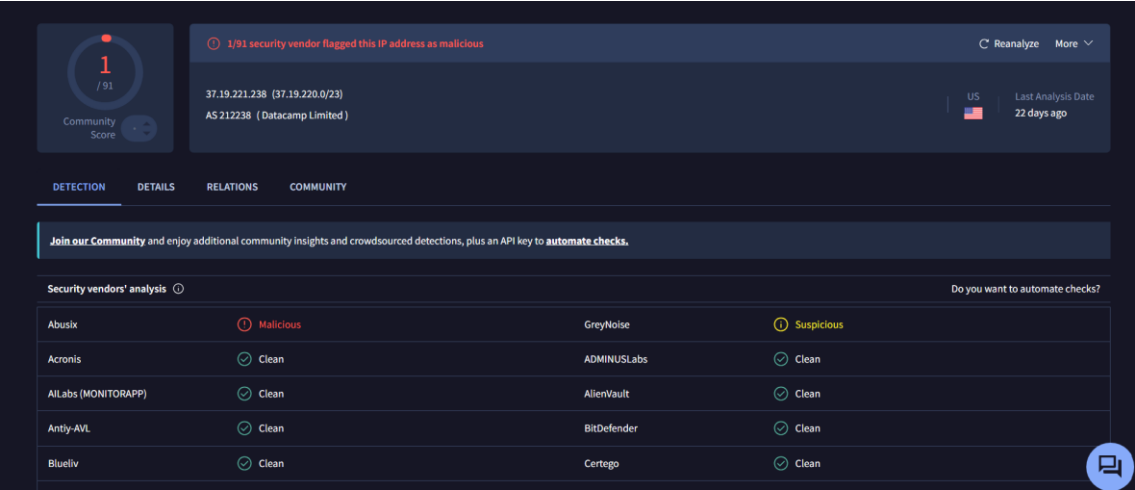
A máquina deve ser contida/isolada da rede

No histórico de comandos não parece que foi baixado algo ainda ou que ele conseguiu extrair algum hash de senha ou pegar alguma outra credencial, o que é bom, mas é melhor verificar nos logs se esse IP também conseguiu invadir outros hosts/contas

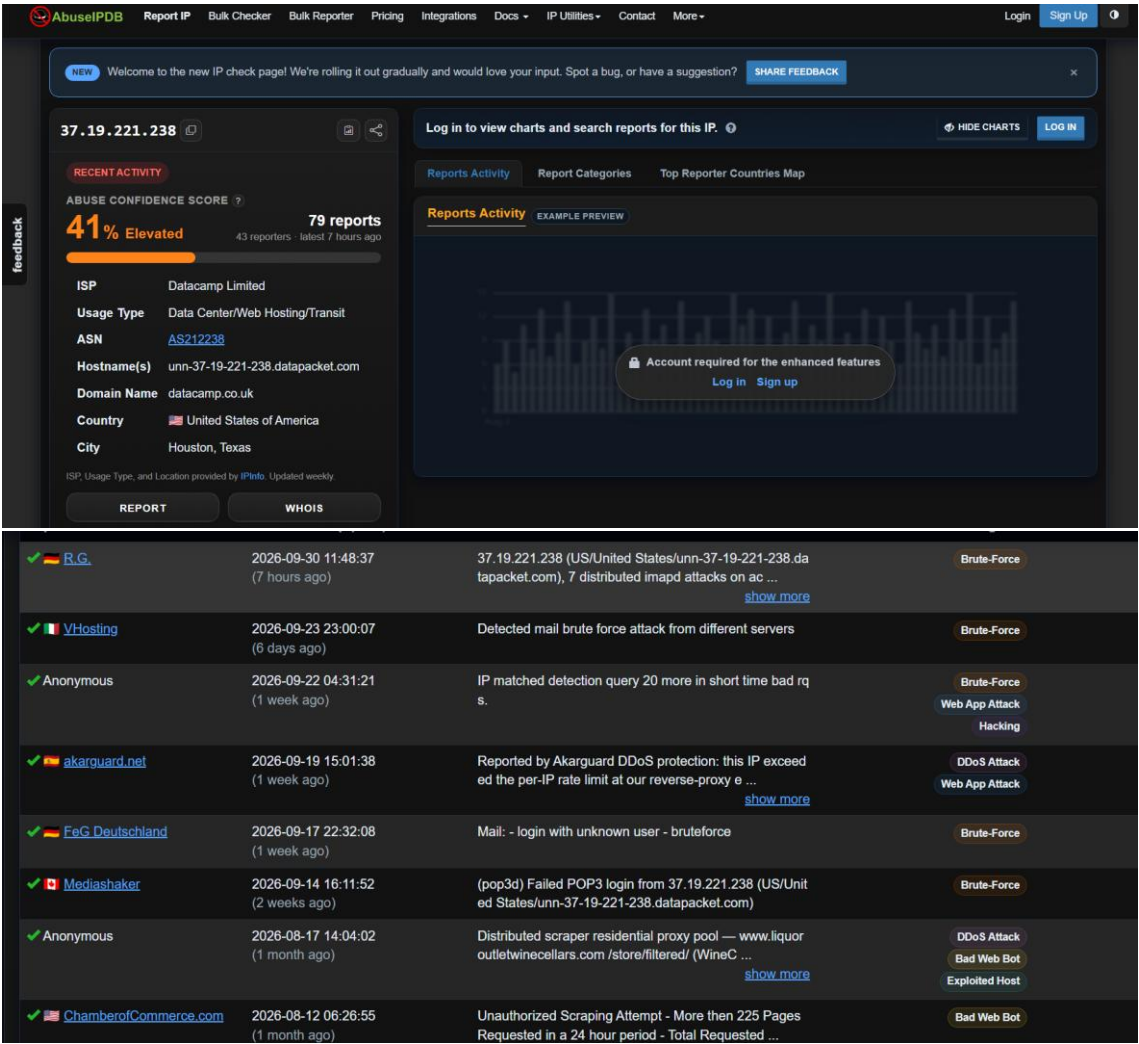


Analisando todos os logs, não parece que ele teve contato com outros hosts ou que conseguiu comprometer outro usuário

É bom fazer uma análise do IP malicioso para o relatório também, isso é possível com ferramentas como virustotal



Isso não indica necessariamente que é suspeito, NEM sempre o virustotal vai estar certo, é sempre bom conferir em outras fontes em casos como esse, uma boa ferramenta para verificar IPS maliciosos pode ser o abuselPDB



T1110 – BruteForce

T1016 - System Network Configuration Discovery

T1057 - Process Discovery

Horário:

10-06-2024 06:56:18

IoCs:

Endereços IP:

37.19.221.238

Comando:

Net time \\EC2AMAZ-ILGVOIN

Vetor de Ataque:

Porta RDP exposta a internet foi alvo de um bruteforce bem-sucedido, o alvo foi o host de IP 172.16.17.213 contra o usuário LetsDefend

Análise:

Um serviço RDP exposto e uma senha fraca ou vazada levaram ao comprometimento de um host.

A sequência de comandos utilizados indicam fortemente um processo de reconhecimento e pouco comum vindo de um usuário legítimo, principalmente após um bruteforce bem-sucedido.

O IP externo que se conectou é conhecido por ataques bruteforce

Outras máquinas/usuários não parecem ter sido comprometidos

Recomendações:

- Isolar a máquina da Rede
- Desabilitar e resetar a senha do usuário Lets Defend
- Bloquear o IP malicioso
- Melhorar a política de senhas
- Não deixar serviços expostos na rede como RDP, a não ser que for de real necessidade
- As mensagens de resposta do RDP estão perigosas, “the user is right, but the password is wrong”, isso facilita a enumeração por parte do atacante, deixe mensagens mais abrangentes como “user or password incorrect”